

STAC4749

PowerShell payload retrieval and tokenized implant launch

A campaign-specific hunting package derived from Sophos MDR observations of Microsoft Teams vishing followed by remote access, PowerShell payload staging in AppData\Roaming, and implant launch with --token-raw.

CLASSIFICATION

Hunting query
Untested implementation
sketch

CONFIDENCE

Medium
Direct behavior; environment
validation required.

OPERATIONAL VALUE

8.2 / 10
Selective endpoint evidence
before ransomware.

PRIMARY PLATFORM

Microsoft Defender XDR
Direct process creation and command-line telemetry in DeviceProcessEvents; stable device and process correlation
keys; no join or threshold required.

Executive Assessment

Decision-grade summary and confidence boundaries

WHAT IS CONFIRMED

Sophos MDR observed Teams support impersonation, remote access, PowerShell retrieval into user-writable directories, and a one-line download-and-launch command containing Invoke-WebRequest, -OutFile, Start-Process and --token-raw.

WHAT IS NOT CONFIRMED

A query match does not prove successful C2, data theft, ransomware deployment or attribution. The token argument can change, and the actor may launch the implant directly or stage it outside AppData.

DETECTION JUDGMENT

The complete command pattern is substantially more specific than PowerShell, Quick Assist, RemSupp, AnyDesk, a .top domain, or a Run key in isolation. It is still campaign-specific and mutable, so the correct status is Hunting, not a Production candidate.

EVIDENCE QUALITY

High
Primary technical research based on direct MDR investigations.

TELEMETRY CONFIDENCE

Medium
Fields documented; local command-line population untested.

BENIGN OVERLAP

Expected low, but must be measured against admin and red-team scripts.

OPERATIONAL USE

Run across 30-90 days, preserve raw events, then pivot to file, network, signer, hash, parent process, user authorization and remote-support inventory before escalation.

Threat Mechanics

Source-observed chain and observability boundaries

1

TEAMS VISHING

External IT-themed account initiates chat/call and persuades the user to grant remote access.

2

REMOTE SESSION

Quick Assist or RemSupp is used; later incidents favored RemSupp. This is legitimate software abuse.

3

POWERSHELL STAGING

An operator downloads an executable to AppData\Roaming using Invoke-WebRequest and -OutFile.

4

TOKENIZED LAUNCH

Start-Process launches the implant with --token-raw carrying token/signature material.

5

FOLLOW-ON ACCESS

Backdoor, Golang implants and optional RMM/tunneling support persistence and C2.

6

POTENTIAL IMPACT

At least three observed compromises later reached Chaos ransomware; not implied by the hunt match.

SCOPE BOUNDARY

The implemented hunt covers stage 3 plus stage 4 in one PowerShell command. It does not detect the Teams interaction or every remote-support path.

Telemetry Model

Required fields, enrichment and data quality gates

Field	Reliability	Purpose
Timestamp	Documented	Event time and triage ordering
DeviceId / DeviceName	Documented	Endpoint pivot and identity
FileName / FolderPath	Documented	PowerShell image context
ProcessCommandLine	Documented; population environment-dependent	All evidence-bearing filters
AccountUpn / AccountName	Documented; population environment-dependent	User and authorization check
ProcessUniqueId	Documented	Preferred process correlation key
ReportId	Documented	Unique event with DeviceName + Timestamp
Signer / hash / network	Optional enrichment	Maliciousness and follow-on pivots

REQUIRED

Microsoft Defender for Endpoint must populate DeviceProcessEvents and preserve a complete command line.

UNAVAILABLE

Teams call content, C2 success, encrypted payloads and ransomware outcome are outside this query.

QUALITY GATE

Reject rule development if command lines are empty/truncated, correlation keys are unstable, or authorized scripts create frequent indistinguishable matches.

Detection Logic

Primary Microsoft Defender XDR hunting implementation

KQL / HUNTING QUERY / UNTESTED

```
// Hunting query - Untested implementation sketch

DeviceProcessEvents

| where FileName in~ ("powershell.exe", "pwsh.exe")

| where ProcessCommandLine contains "Invoke-WebRequest"

| where ProcessCommandLine contains "-OutFile"

| where ProcessCommandLine contains "--token-raw"

| where ProcessCommandLine contains "Start-Process"

| where ProcessCommandLine contains @"\\AppData\\Roaming\\"

| project Timestamp, DeviceId, DeviceName, AccountUpn, AccountName,

    FileName, FolderPath, ProcessCommandLine,

    InitiatingProcessFileName, InitiatingProcessCommandLine,

    ProcessId, ProcessUniqueId, ReportId

| order by Timestamp desc
```

CONDITION EVIDENCE

Every string except pwsh.exe is present in the source command. pwsh.exe is an explicit defensive coverage assumption and may be removed for strict campaign fidelity.

NO ARBITRARY LOGIC

No threshold, rarity, join, sequence, aggregation or allowlist is embedded.

CORRELATION

Prefer DeviceId + ProcessUniqueId; retain DeviceName + Timestamp + ReportId.

Triage Workflow

Evidence collection before escalation

1. CONFIRM RAW EVENT

Verify the complete command line, path, user, device, parent and process keys.

2. VALIDATE AUTHORIZATION

Check change records, software deployment systems, red-team activity and admin ownership.

3. PIVOT TO FILE EVIDENCE

Collect target path, hash, signer, creation origin and subsequent process launches.

4. PIVOT TO NETWORK

Inspect outbound connections from the launched process; do not infer C2 success from execution.

5. REVIEW REMOTE ACCESS

Establish whether Quick Assist, RemSupp or another RMM session was authorized.

6. SCOPE FOLLOW-ON ACTIVITY

Look for Run keys, Startup shortcuts, additional RMM, proxy tooling and ransomware artifacts.

ESCALATION GATE

Escalate when the command is unauthorized and corroborated by suspicious payload hash/signer, attacker-controlled destination, remote-support abuse, persistence or follow-on C2. Do not escalate solely because PowerShell wrote to AppData.

INVESTIGATION KEY

DeviceId + ProcessUniqueId

EVENT IDENTITY

DeviceName + Timestamp + ReportId

False Positives & Validation

Operational controls before rule development

Potential benign source	Tuning evidence	Do not do
Enterprise deployment script	Signed script/hash, repository, ticket, service account	Allowlist all PowerShell
Vendor updater or support tool	Publisher, stable path, expected URL, approved owner	Allowlist all AppData
Red-team simulation	Engagement window, operator account, payload hash	Suppress indefinitely
Developer test harness	Repository and repeatable command provenance	Assume --token-raw is malicious

VALIDATION PLAN

Run for 30-90 days; inspect every raw event; reproduce a benign equivalent in a controlled host; verify command-line completeness; measure whether authorized activity is separable with stable attributes.

SUCCESS

Complete events, stable pivots, low and explainable volume.

REJECTION

Frequent benign overlap with no stable discriminator.

FAILURE

Missing/truncated command line or inadequate retention.

ATT&CK & References

Supported mapping, conclusion and publication controls

T1059.001 - POWERSHELL

Directly supported by the observed PowerShell command used to retrieve and launch the payload.

T1105 - INGRESS TOOL TRANSFER

Directly supported by Invoke-WebRequest downloading the executable to the endpoint.

CONCLUSION

Publish as a campaign-specific hunt. Validate locally before alerting. Maintain the behavior chain as the investigation anchor; treat domains, filenames, Run key labels and certificate issuers as enrichment only.

PRIMARY RESEARCH

Sophos X-Ops, Chaos in Teams vishing, published 28 Jul 2026; observed Feb-Jun 2026.
<https://www.sophos.com/en-us/blog/chaos-in-teams-vishing>

OFFICIAL DOCUMENTATION

Microsoft Learn, DeviceProcessEvents advanced hunting schema.
<https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>

Microsoft Learn, DeviceRegistryEvents advanced hunting schema.
<https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceregistryevents-table>

PUBLICATION QA

8 A4 pages; no customer data; URLs defanged; no HTML, render source or intermediate assets are part of the repository package.